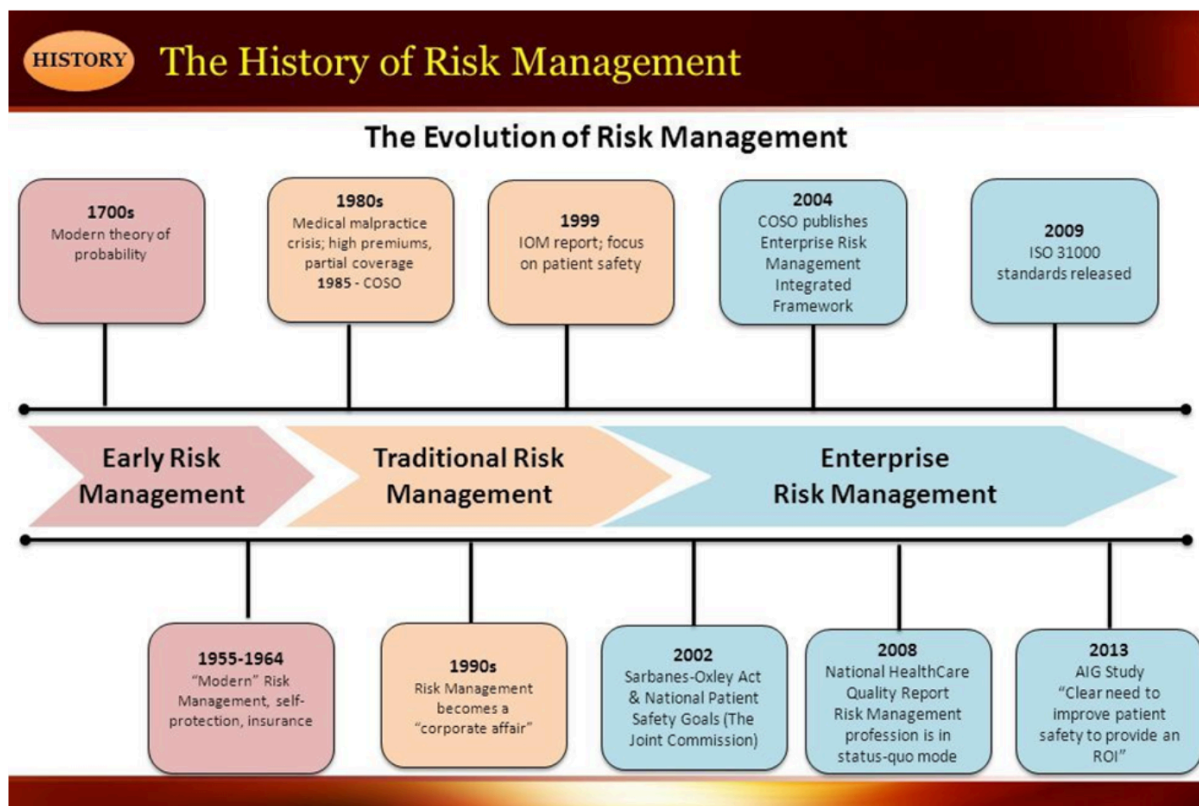


# Information Risk Management

## Information Risk Management →

Information risk management refers to the systematic application of management policies, procedures, and practices to establish the context, identify, analyze, evaluate, treat, monitor, and communicate information security risks. It involves implementing effective measures to protect information assets, ensure compliance with legal and regulatory requirements, and make informed decisions based on a rigorous risk management process.



Information risk management is the process of determining how a disruptive incident can affect a company and how to prepare for and control the various threats and vulnerabilities that come with the usage of information technology.

- It includes any circumstance in which the CIA (Confidentiality, Integrity, and Availability) of data is compromised.

- **Confidentiality:** Establish and enforce appropriate authorization controls so that only users who need access have access
  - **Integrity:** Establish and enforce controls that prevent changing information without data owner permission
  - **Availability:** Establish and enforce controls that prevent systems, networks, and software from being out of service
  - It involves the monitoring of all of the rules, regulations, policies, and human actions that make up the risk environment for data, as compared to information security, which focuses on technology.
- 

### **Importance of Information Risk Management →**

- Makes the working environment safer
  - Manage risk
  - Enables project success
  - reduces unexpected events
  - Creates financial benefits
  - Saves time and efforts
  - Improves communication
  - Prevents reputational issues
  - Benefits culture
  - Guides decision-making
- 

### **Purpose of Information Risk Management**

The vulnerabilities in information or the contexts in which it is processed necessitate information risk management. These are inevitable during your routine business operations, combined with the threats of exploitation that exist

both inside and outside the business. Information risk management was created in order to acknowledge, account for, reduce, and ultimately eliminate these risks.

**There are four general metrics that a sound strategy should use to inform its goals and accomplishments:**

- Identifying and documenting every digital asset used, together with the basic guidelines for its use, in order to create a baseline for mapping and comparing suspicious behavior.
  - Continuously looking for potential threats and vulnerabilities that could compromise assets, both internally and in wider sections of the public and dark web.
  - Designing roles and responsibilities for rapid and effective mitigation when a known or unknown risk materialises as an incident.
  - Automating or otherwise coming out with the most effective ways to guarantee data confidentiality, integrity, and availability without compromise.
- 

### **IRM ( Information Risk Management ) Process →**

Identifying the location of information, analyzing the type of information, prioritizing risk, establishing a risk tolerance for each data asset, and continuously monitoring the enterprise's IT network are crucial steps that organizations implementing an IT risk management (IRM) program need to take.

#### **1. Identify potential points of vulnerability**

Finding the locations where your data is stored seems clear enough conceptually. Most businesses start with their databases or teamwork programs. But as more businesses choose cloud-first or cloud-only strategies, data becomes more fragmented and susceptible to cyber threats.

Nowadays, many people use serverless or other cloud-based storage locations like shared drives. Moreover, a lot of firms now use innovative methods to collect data, like customer-facing online portals. The way that businesses share information with internal and external stakeholders has also changed as a result of new data transmission channels like email and messaging services.

## **2. Analyze data types**

You must be aware of both the location of your data and the type of data you are collecting. Data types are not all created equal. Information like a person's name, birth date, social security number, or even IP address is considered personally identifiable information. The information is a high-risk asset since malicious entities frequently target PII because they can sell it on the Dark Web.

Meanwhile, you also store low-risk information, such as marketing copy. If malicious actors obtain a copy of a blog post, for instance, they can't sell that online.

The basis of risk analysis is identifying the types of data that any organization maintains and correlating those types to the locations where organizations store their information.

## **3. Evaluate and prioritize the information risk**

After reviewing and categorizing all data assets, you must now assess the risk. There is a specific location where each type of data asset is located. You must ascertain how each risk interacts with the others and influences the likelihood of an attack by a malicious attacker. The best way to do this is to calculate:

**Risk Level = Likelihood of a data breach \* Financial impact of a data breach**

For example, A high-risk location, like a file-sharing tool, may contain a low-risk data asset like marketing copy. However, if a malicious person steals the information, the financial impact on your business will be negligible. As a result, this might be considered low or moderate risk.

Meanwhile, A client's medical file is a high-risk data asset that would have a significant financial impact in a moderate-risk environment like a private cloud. As a result, your organization would virtually always view this as having a high risk.

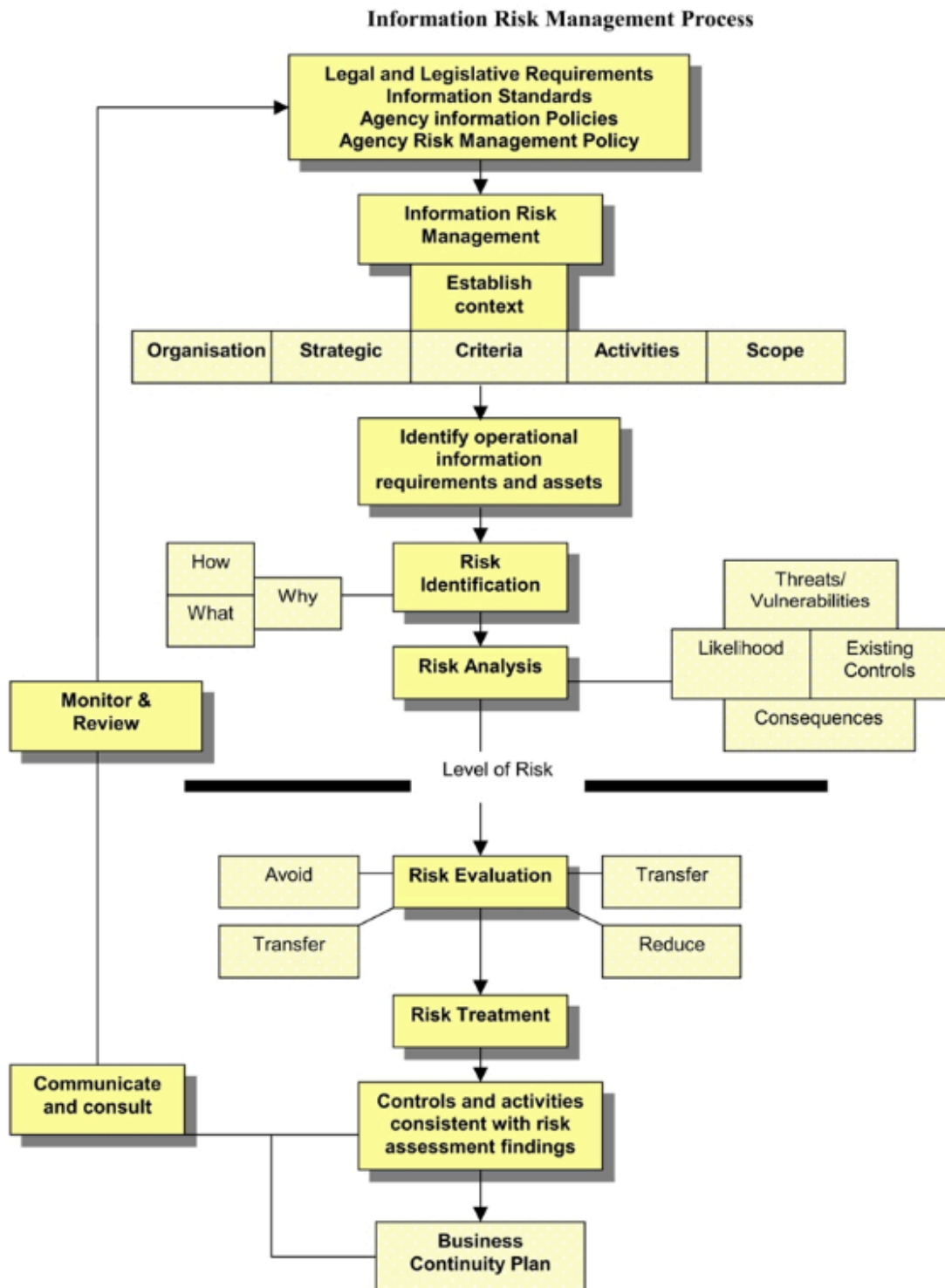
## **4. Set a risk tolerance and establish IT risk management processes**

A risk can be accepted, transferred, mitigated, or rejected depending on your risk tolerance. Purchasing cyber risk liability insurance is an example of control for transferring risk. Installing a firewall to block access to the site where the data is stored is an example of control for mitigating risk.

Firewalls or encryption are examples of mitigating controls that serve as barriers to cybercriminals. Even mitigating controls sometimes can fail.

## **5. Continuously monitor your risk**

Malicious entities are always changing how they pose a threat. Malicious entities have reacted by concentrating more on cryptocurrency and phishing as businesses become more adept at detecting and safeguarding against new ransomware attacks. In other words, today's effective controls could become vulnerable in the future.



## Best practices for information risk management

## **1. Know Your IT Environment and Assets**

Effective risk management requires an in-depth understanding of the IT environments and resources within your company. All data and other digital assets, BYOT devices, networks, systems, third-party components and services, technologies, endpoints, and other items are included in the scope of the IT environment that your organization has to be aware of. You must continue setting asset priorities and monitoring the IT environment. By doing this, you may take up more effort to protect your most critical and valuable assets.

## **2. Develop a Robust Risk Management Strategy**

It might be detrimental to manage risks without having a solid risk management strategy and plan. Organizations must therefore create sound strategies and plans and maintain them up to date. Prior to planning, you must determine your level of risk tolerance and create a risk profile. Also include employee and other key stakeholders' roles, incident response and escalation strategies, and other relevant information in your risk management plans. Develop best practices that employees can use, and incorporate employee training into your plan. This is because folks are frequently the weakest link in a system.

## **3. Embed Risk Management into Your Culture and Values**

If risk management policies and procedures are not adequately applied throughout the organization, they are of little use. So make sure to convey your ideas, plans, and procedures to all individuals involved. Incorporate risk management with the culture and values of the company. Each one in the organization must be aware of and understand their responsibilities in risk management.

## **4. Risk Assessments Must be Adaptive, Continuous, and Actionable**

Risk identification and assessment are two of the most crucial aspects of risk management. Risks are continuously evolving. A change in company procedures or the introduction of new technologies may occur. As a result, the organization's risk profile varies. To ensure effective security, the procedures must be continuously assessed for flaws and updated.

## **5. Enforce Strict Security Protocols**

Comprehensive and intuitive security is necessary for effective risk mitigation. Here are some ways to do it:

- Employ an intelligent and managed Web Application Firewall placed at the edge of the network. It should monitor traffic, provide actionable, real-time insights, and round-the-clock security against known and emerging threats.
- Employ automated patching where possible.
- Enforce strict authentication policies and access controls.
- Extend security to all devices in your IT environment including BYOT devices.
- Enforce strict security protocols for remote workers as well.
- When possible, consolidate systems and data into one source as scattered and siloed data are harder to monitor and protect.
- Backups and updates are indispensable.

## **6. Real-time and Reliable Visibility is Necessary**

A trustworthy insider within the organisation, a third-party component with built-in flaws, avoidable human error, etc. are all examples of evolving risks. It's essential to have reliable, real-time visibility of the organization's changing risk profile. Risk mitigation works effectively when it is based on real-time insights.

---

## **What is IRM framework?**

An IRM framework is typically a smaller subset of a larger RMF, linked to the specific types of information that an organization employs as well as the specific risk factors and risk environment that surround this information. Legal or regulatory limits that are relevant to that information or its components may be the main factor. It may involve specific characteristics of the data, such as with PII.

---

## **The Benefits of an IRM Framework**



- Robust Information Risk Management brings competitive advantage through an increase in trust that will improve the company's reputation for better sales results.
  - Effective Information Risk Management lowers the chances of a damaging information security incident. It will help you understand your risks and what you need to do to avoid a breach.
  - Mastering Risk Management gives you the visibility and confidence to make better business decisions – decisions based on real risks, not rumour or scaremongering.
  - Information Risk Management can save money through more efficient controls, more effective architectures and appropriate levels of protection.
  - Information Risk Management includes business continuity, keeping the business going in unforeseen circumstances or emergencies.
  - Information Risk Management gives you full visibility. Knowing where your information is will enable you to put your hands on the right details fast, faced with any request for information (e.g. HR/legal)
  - Understanding and managing your risks brings peace of mind – you can be confident that you have taken due care and diligently exercised risk management in accordance with your business requirements.
-